ReleaseProof

FIRMWARE MIGRATION ASSURANCE · INTELLIGENT INDUSTRY

A firmware can boot and still be impossible to upgrade safely.

ReleaseProof checks the **migration path**, not just the new image: real builds, real emulation, a **deterministic verdict**. AMD-hosted AI plans and explains. **It never decides.**

2 live configurations · Nordic nRF52840 | wolfBoot & MCUboot | ECDSA P-256 → ML-DSA | ≈1 min per run | every artifact sha256-hashed

OVERALL MIGRATION · WOLFBOOT · ECDSA P-256 → ML-DSA-87

INCOMPATIBLE

Candidate: does the new image boot?	Compatible
Transition: can deployed devices get there?	Incompatible

```
LIVE run RP-20261017T124806Z-a39610
8/8 tests · 61 hashed artifacts · engine contract V1.2
sha256:a22d6efc4a84…6e54 · non-official engineering assessment
```

Values copied from a real run of the app (Renode emulation, 17 Oct 2026).

THE PROBLEM

Post-quantum deadlines are hitting device fleets that were never built to change their root of trust

2030
NSA CNSA 2.0

Software & firmware signing: CNSA 2.0 only

"Begin transitioning immediately, support and prefer by 2025, exclusively use by 2030." Firmware signing has the earliest deadline in the suite.[1]

2027
EU CRA

Cyber Resilience Act fully applies on 11 Dec 2027

Products must be maintainable with security updates. Vulnerability reporting has applied since 11 Sep 2026.[2]

2035
NIST IR 8547

ECDSA and RSA signatures disallowed after 2035

The 112-bit variants are deprecated after 2030 (initial public draft).[3]

39 B
IOT, 2030

21.1 B connected devices in 2025 → 39 B by 2030

Connected products often stay in service for 10–20 years. Their bootloader keys were chosen long before PQC.[4][5]

The trap: "boots" ≠ "migrates"

LAB TEST: CANDIDATE STATE

ML-DSA-87 bootloader + ML-DSA-87 signed image → Boots

```
UART: version frame 2a 00 00 00 01 → v1 running
```

FIELD REALITY: THE TRANSITION

Deployed ECDSA P-256 bootloader
no self-update on nRF52840

← OTA: ML-DSA-87 update → Rejected

```
UART: "Update type invalid 0xB01≠0x200"; v1 keeps running
```

Per-algorithm boot tests come back green, yet the fleet cannot get there. Finding that out after shipping means recalls, depot re-flashes or stranded devices.

Both lanes were measured live by ReleaseProof (wolfBoot @4c79eee, Renode 1.16.1, run RP-20261017T124806Z-a39610).

[1] NSA, CNSA 2.0 Algorithms CSA, May 2025 · [2] European Commission, CRA summary (digital-strategy.ec.europa.eu) · [3] NIST IR 8547 ipd, Nov 2024 · [4] IoT Analytics, Oct 2025 · [5] ONEKEY, "PQC for connected devices", Jul 2026

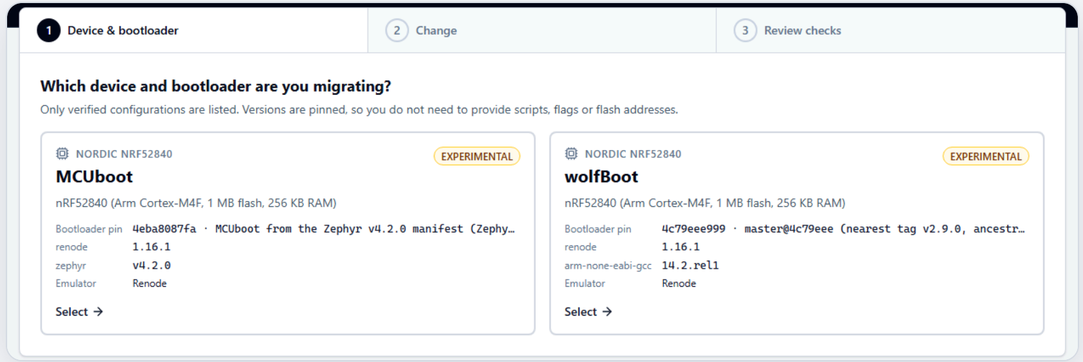
THE SOLUTION, LIVE

Choose a configuration and a change, and get a verdict backed by evidence in about a minute

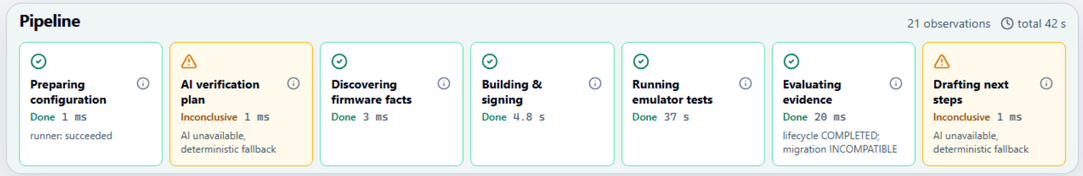
1 Pick a verified configuration
Device + bootloader with pinned commits and toolchains. No scripts, flags or flash addresses to type.

2 Pick the change
For example ECDSA P-256 → ML-DSA-87. Review the required checks and the ones the AI may add.

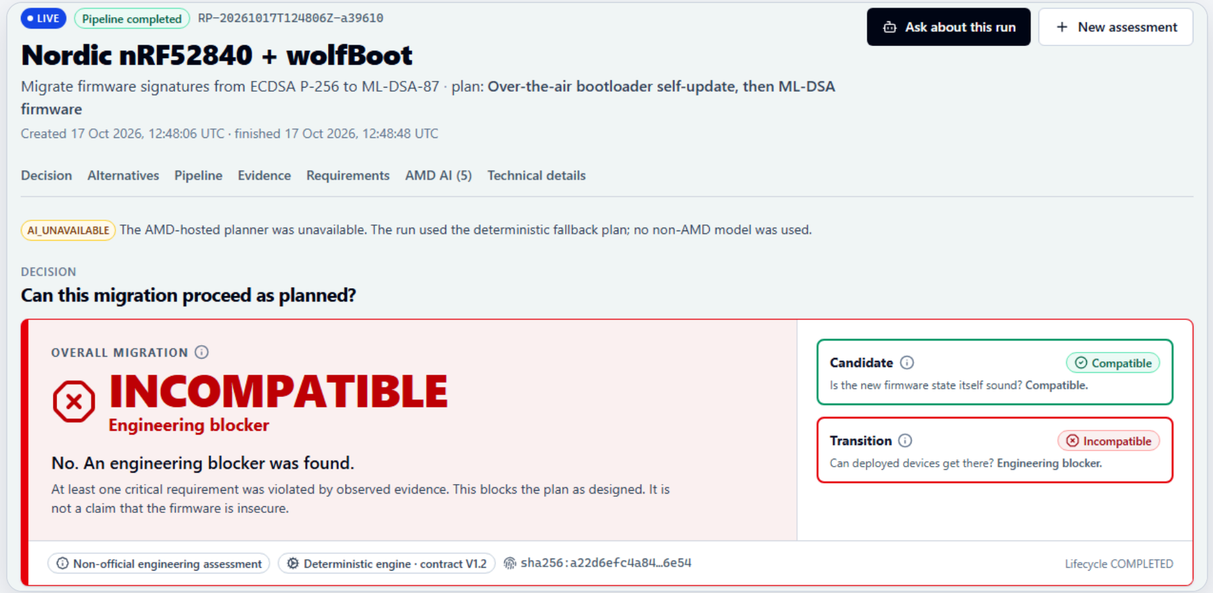
3 Run: it really executes
Builds and signs with ephemeral keys, then boots and updates in Renode. Positive and negative tests feed the V1.2 verdict, canonical hash and manifest.



Wizard: configurations with pinned versions. Both still carry the EXPERIMENTAL flag until they are formally promoted.



Live pipeline: 7 stages streamed from the runner (SSE), 21 observations, 42 s in total.



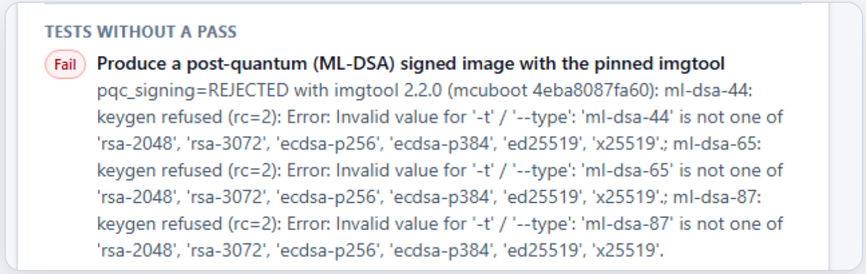
Decision: candidate and transition are judged separately, by the engine and not by the AI. LIVE run **`RP-20261017T124806Z-a39610`**. Every evidence row links to sha256-hashed artifacts: UART captures, ELF files, signed images and Renode scripts.

TWO CONFIGURATIONS, BOTH RUNNING END TO END

Same chip, two bootloaders, and two different reasons the migration fails

	nRF52840 + wolfBoot change: ECDSA P-256 → ML-DSA-87	**nRF52840 + MCUboot (Zephyr)** change: ECDSA P-256 → ML-DSA
Pinned stack	`wolfBoot 4c79eee · wolfSSL 4aa1ad7 · Arm GCC 14.2.rel1`	`MCUboot 4eba8087 · Zephyr v4.2.0 · SDK 0.17.4 · imgtool 2.2.0`
Emulation	Renode 1.16.1, nRF52840; SVD baked in and sha256-pinned	Renode 1.16.1 with ReleaseProof's own NVMC flash model (MIT), swap-using-move
Candidate check	ML-DSA-87 bootloader and image built and **booted** (E02); signed image 12 876 B fits the 262 144 B slot	PQC signing attempt with the pinned tool (E02): **imgtool refuses ml-dsa-44/65/87** (measured)
Field-update path	Source inspection (E11): no nRF52 self-update path (`RAM_CODE=0`)	Partition map + Kconfig (E11): single-stage MCUboot, no bootloader slot
Negative tests	Tampered image rejected (E03) · deployed ECDSA bootloader rejects the ML-DSA update (X01) · candidate rejects an ECDSA image (P01)	Tampered image rejected (E03) · update signed with another key rejected (X01)
Engine verdict	Candidate COMPATIBLE · Transition INCOMPATIBLE REQ-BOOT-S0S1 violated · run a39610 · 8/8 tests · 61 artifacts	Candidate INCOMPATIBLE · Transition INCOMPATIBLE REQ-PQC-VERIFIER + REQ-BL-FIELD-UPDATE · run 7682fc · 7/7 tests · 50 artifacts

Why the checks differ: the test semantics are bootloader-agnostic (E01 current boots, E02 candidate, E03 auth-negative, X01 cross-transition, E05 layout, E11 field-update capability). Each profile maps them to its own build and emulation templates. **Runners measure; only the engine decides.** A missing observation becomes `UNKNOWN`, never a pass.



Sources: profiles/*.yaml, runners/*/README.md, docs/acceptance/*.json (acceptance gate passed for both profiles)

THE AGENTIC LOOP

The AI proposes, the emulator measures, the engine decides, and a human chooses the next step

AMD-HOSTED AI

① Plan tests

Picks and orders the optional registered checks. Required checks always run, and unknown templates are blocked and shown.

→

RUNNER

② Execute for real

Pinned build, ephemeral keys, Renode boot and update, UART capture. No network access, and every artifact is hashed.

→

V1.2 ENGINE

③ Deterministic verdict

Candidate, transition and migration verdicts plus an explanation graph and a canonical hash. Golden-hash regression tests guard it.

→

AMD-HOSTED AI

④ Explain + alternatives

Explanations must cite real evidence IDs. Alternatives come only from the profile's allowed set and are labelled PROPOSAL.

→

HUMAN + ENGINE

⑤ Re-evaluate

A human picks an alternative. That creates a **new** run with a parent reference, and history is never changed.

↺ the re-evaluation feeds back into ③ or, when new tests are needed, starts a new LIVE run at ②

`LIVE · RP-20261017T124806Z-a39610 · bootloader_self_update`

INCOMPATIBLE

REQ-BOOT-S0S1 is violated: the deployed wolfBoot cannot replace itself over the air on nRF52840.

→ human clicks "Evaluate this plan"

`REEVALUATION · RP-20261017T124931Z-72d0b1 · field_service_reflash`

INDETERMINATE

The blocker is gone, but recovery from an interrupted update (INV-I4) was never observed, so the result is an honest unknown and not a pass. The parent's hash is unchanged.

Schema-validated structured output; bad JSON is repaired once, otherwise rejected

Citation check: every claim must reference evidence that exists in this run

Verdict-echo check: AI text that contradicts the engine verdict is discarded

Allow-listed AMD host and no fallback provider. If the AI is down: `AI_UNAVAILABLE` and the deterministic plan runs

Tool output is untrusted: UART and log text is wrapped against prompt injection

No shell from the AI: it can only choose allow-listed templates

Status: the AMD endpoint key is pending, so today's screenshots show AI_UNAVAILABLE with the deterministic fallback, as designed. The guardrails are implemented and unit-tested in backend/releaseproof/ai.

ARCHITECTURE ON AMD

An AMD EPYC host runs the builds and emulation, and an AMD Instinct-hosted LLM does the reasoning

AWS EC2 C7A.2XLARGE · AMD EPYC (GENOA) · DOCKER COMPOSE

DEPLOY PENDING · [[DEMO_URL]]

Browser · Next.js UI
wizard · live run (SSE) · evidence · alternatives · AMD panel

Caddy
auto-TLS edge · /api → api · / → web

FastAPI api
orchestrator state machine · queue · SQLite · artifacts · manifests

↓ HTTP / NDJSON (internal network, no egress)

runner-wolfboot
wolfBoot + wolfSSL · Arm GCC 14.2 · keytools · Renode 1.16.1 · own SVD

runner-mcuboot
Zephyr v4.2.0 sysbuild · MCUboot · imgtool 2.2.0 · Renode + NVMC model

↓ typed observations + artifact sha256

Assessment adapters
observations → V1.2 assessment; missing fact ⇒ UNKNOWN / gap

V1.2 semantic engine
validate · evaluate · explanation graph · canonical hash

AI gateway
planner · explainer · alternatives · assistant; schema, citation and verdict-echo guards; traced

↓ persisted per run

Run record (immutable)
verdicts · explanation graph · gap plan · dossier · `manifest.json` with inputs, pins, artifact sha256 and result hash · AI traces

Run lifecycle: PREPARING → AI_PLAN → DISCOVERY → BUILD_SIGN → EMULATION_TESTS → EVALUATION → NEXT_STEPS. If a runner is killed or crashes, the run is FAILED and no verdict is issued. Secrets live only in the api container.

AMD EVIDENCE

LLM on AMD Instinct (AMD Developer Cloud)
OpenAI-compatible, allow-listed host only, reached through API egress only

HOST CPU	AMD EPYC 4th gen (EC2 c7a.2xlarge, 8 vCPU) runs builds, Renode and the engine
GPU	[[AMD_HARDWARE]]
MODEL	[[AMD_MODEL]]
SERVING	[[AMD_SERVING_STACK]]
P50 LATENCY	[[AMD_LATENCY_P50]]
SCHEMA-VALID	[[AMD_SCHEMA_VALID_RATE]] scripts/amd_benchmark.py also measures citation fidelity, verdict echo and injection leaks
ON AMD	Every LLM call, plus the full pipeline once deployed on EPYC

Yellow tags are placeholders, filled only with measured values. Nothing on this slide is invented: the AMD endpoint and AWS deployment were still pending when the deck was written.

EVALUATION

One business result, one failure case, one limitation and one human safeguard

BUSINESS RESULT · MEASURED

A blocker that boot-only testing misses, found in under a minute and backed by evidence

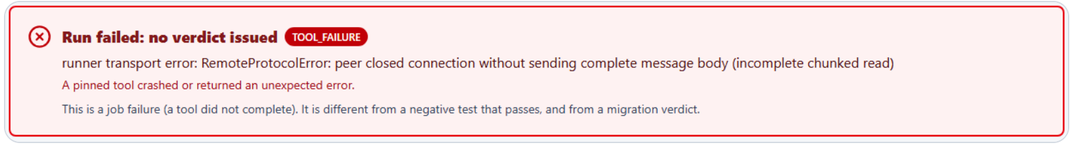
wolfBoot: the ML-DSA-87 candidate boots (a boot-only check would report PASS), but deployed devices cannot get there. The engine shows this with cited evidence before any device is touched.

42 s	8/8	21	61
WALL TIME	TESTS RUN	EVIDENCE ITEMS	HASHED ARTIFACTS

Run a39610. MCUboot run 7682fc: 75 s, 7/7 tests, 50 artifacts. Manual-effort savings are not claimed as measured.

FAILURE CASE · OBSERVED

Runner killed mid-run ⇒ FAILED, and no verdict is issued



Run `RP-20261017T124942Z-23dd8f`: `/result` returns 409 and there is no fallback to recorded data. Our own acceptance gate also **failed** a wolfBoot run when Renode tried to download its SVD on the no-egress network. E01 was reported INCONCLUSIVE instead of being faked, and we fixed it by baking in and pinning the SVD.

KNOWN LIMITATION

This is emulation, not silicon, and only two configurations are supported

- Renode models nRF52840 flash as plain memory (wolfBoot), and our NVMC model for MCUboot is minimal, so there are no power-loss or timing faults.
- Interrupted-update recovery (E12) is not executed, so INV-I4 stays **UNKNOWN**.
- Verdicts are non-official engineering assessments, not certifications.
- The AMD LLM was not connected for today's runs, so they used the deterministic fallback plan.

SAFEGUARD · HUMAN REVIEW

The AI never changes a verdict. An engineer chooses and signs off

- AI output is labelled PROPOSAL, and choosing an alternative creates a new run.
- Alternatives marked REQUIRES_EXTERNAL_VALIDATION are refused (HTTP 422).
- Every result carries the engine version, canonical hash and manifest of inputs, pins and artifact hashes, so a reviewer can trace each claim.
- The "Ask about this run" assistant only produces text from the run's evidence. It has no tools and cannot start runs.

MARKET AND BUSINESS MODEL

Regulation creates the demand, and every device configuration is a product

MARKET (THIRD-PARTY ESTIMATES)

$2.84 B
PQC market 2030 · 46.2% CAGR

Up from $0.42 B in 2025. Includes migration services and quantum risk assessment, with Europe growing fastest.
MarketsandMarkets, Oct 2025

$4.35 B
secure boot & firmware security 2030

Up from $2.91 B in 2025 (8.4% CAGR). IoT and embedded is the fastest device segment (9.6%) and OTA update frameworks are the fastest-growing category.
Mordor Intelligence, Jul 2025

$255 M
PQC assessment & planning, 2025

The first wave of PQC spend goes to assessment and transition strategy, which is exactly where a verdict on the migration path fits.
ABI Research, Apr 2025

€15 M
or 2.5% of turnover

Maximum CRA fine for breaching essential requirements, including security-update obligations.
Regulation (EU) 2024/2847, Art. 64

WHO PAYS: DEVICE OEMS, EMBEDDED INTEGRATORS, OPERATORS OF LONG-LIVED FLEETS

Configuration-profile subscription — RECURRING

Per device + bootloader + toolchain profile, kept pinned and re-validated as upstream changes. Covers wolfBoot, MCUboot and future bootloader families.

Per assessment / CI integration — USAGE

Metered LIVE runs, or a CI gate that checks every release candidate's transition path and exports the evidence dossier.

Custom profile onboarding — ONE-OFF

Bringing an OEM's own board and bootloader fork into the registry, with acceptance-gated promotion to SUPPORTED.

Go-to-market — PLAN

Start with embedded consultancies and integrators already selling PQC readiness assessments, since they get a repeatable, evidence-backed deliverable. Then land CI seats at their OEM clients.

Pricing hypothesis, not validated: about €1–2k per profile per month, €0.5–1k per month per CI pipeline plus metered runs, €10–25k per custom profile. It will be tested with design partners. No ROI figure is claimed.

marketsandmarkets.com (PQC market, Oct 2025) · mordorintelligence.com (secure boot & firmware security, Jul 2025) · abiresearch.com (PQC press release, 29 Apr 2025) · eur-lex.europa.eu (Regulation (EU) 2024/2847). These analyst estimates differ by source.

COMPETITIVE LANDSCAPE

Others inventory the crypto, ship the update, or test each algorithm alone. We verify the transition

Category · examples	Finds crypto / components in binaries (CBOM, SBOM)	Delivers OTA updates to fleets	Builds & boots each algorithm in emulation	Executes the deployed → candidate transition	Deterministic verdict + alternatives with evidence
Binarly · ONEKEY static binary analysis, CBOM / PQC-readiness reports, CRA compliance workflows	✓	—	—	—	**compliance evidence**
Finite State · NetRise binary SBOM and firmware supply-chain risk	✓	—	—	—	—
Memfault · Mender · Golioth device management, OTA delivery, observability	—	✓	—	—	—
wolfBoot upstream CI GitHub Actions + Renode on nRF52840, one job per signing config (incl. ML-DSA-44/65/87), same-scheme v1→v2	—	—	✓	—	—
ReleaseProof migration-path assurance for a pinned configuration	**config & pin discovery**	—	✓	✓	✓

Our wedge

The cross-generation test (X01) puts the **deployed** bootloader in front of the **candidate's** image. Combined with field-update capability and negative tests, it answers the question a CBOM or per-algorithm CI cannot: **can this fleet actually get there?**

Complementary, not a replacement

A CBOM tells you *what* to migrate, an OTA platform *delivers* the update, and ReleaseProof tells you *whether the path works* before you ship. They are integration partners as much as competitors.

Based on public product documentation as of Oct 2026 (docs.binarly.io CBOM/PQC report; onekey.com; wolfSSL/wolfBoot .github/workflows/test-renode-nrf52.yml). No head-to-head benchmark was run, so the matrix describes focus, not quality.

ROADMAP AND ASK

From two emulated configurations to a release gate for every device fleet

REAL TODAY

Built during the hackathon

- 2 LIVE configurations passing the acceptance gate
- Deterministic V1.2 engine with golden-hash regression tests
- Re-evaluation runs, immutable history and a failed-run policy
- Guardrailed AMD-only AI gateway, with 249 tests green at the integration checkpoint

NEXT 30 DAYS

Close the open items

- Connect the AMD endpoint and publish the benchmark
- Public deployment on EC2 c7a (AMD EPYC)
- Interrupted-update test (E12) via power-fail injection
- Staged hybrid ECDSA + ML-DSA plan; LMS once upstream lands (MCUboot PR #2707)

3–6 MONTHS

Scale the registry

- More boards (STM32, NXP) and bootloader families
- Hardware-in-the-loop runner on real dev kits
- CI action plus evidence pack for CRA technical files (not a certification)
- Key-rotation and layout-change rulesets

Our ask

- **Design partners:** OEMs and integrators with ECDSA-signed fleets that face CNSA 2.0 or CRA
- **AMD Developer Cloud capacity** to benchmark open models on Instinct for planning and explanation
- **Maintainer feedback** from the wolfBoot, MCUboot and Zephyr communities on test semantics

Team & links

team	[[TEAM]]
demo	[[DEMO_URL]]
video	[[VIDEO_URL]]
code	[[GITHUB_URL]] MIT

ReleaseProof: a firmware can boot and still be impossible to upgrade safely.